

Table of Contents

Cisco Secure Workload — UK NCSC Cyber Assessment Framework (CAF)

Technical Runbook | Operators of Essential Services & GovAssure

Version: 1.0 **Framework:** NCSC Cyber Assessment Framework (**CAF v3.2**, published November 2024) — 4 objectives · 14 principles · Indicators of Good Practice (IGPs) with three-tier maturity (Achieved / Partially Achieved / Not Achieved) **Use Case:** OES self-assessment or regulator-led audit under **NIS Regulations 2018 (UK)**; central-government departments / arm's-length bodies under **GovAssure**; voluntary adoption by other CNI operators.

Framework version note. CAF v3.2 is the current NCSC-published baseline; sector regulators (Ofgem, Ofcom, DWI, CAA, ORR, MCA, DHSC/NHS England) may layer sector-specific profiles or add IGP guidance on top. Confirm the profile your Competent Authority uses before finalising evidence. This runbook cites CAF principle IDs (A1–D2) and IGP themes; specific IGP text is authoritative in the NCSC publication.

Scope boundary. CSW is a workload-segmentation and observability product operating on **servers, VMs, containers, and cloud workloads**. Where CAF principles reference OT / ICS field devices (PLCs, RTUs, HMIs, IEDs, SCADA controllers) or industrial protocols (Modbus, DNP3, S7, OPC UA, BACnet), CSW is **not** the enforcement point — pair it with an OT-native product (Cisco Cyber Vision, Claroty xDome, Nozomi Networks). CSW's role is to harden the **IT-side workloads** that support essential services (jump hosts, historians, engineering workstations, IT/OT DMZ workloads, identity/PKI, patch/AV servers, monitoring stacks) and to evidence the **IT-side** of the IT/OT boundary.

CSW UI navigation note. Cisco does not yet publish CAF-specific UI navigation; framework-specific paths are on the product roadmap. This runbook describes CSW *capabilities* and the *evidence artifacts* they produce — those artefacts map to CAF IGPs regardless of UI cosmetics.

Reader's Guide

Who this is for. UK CNI operators — Energy (electricity, gas, oil), Water, Transport (air, maritime, rail, road), Healthcare (NHS Trusts and their suppliers), Digital Infrastructure (DNS, IXPs, TLD registries) — and central-government departments preparing for a **GovAssure** third-party CAF assessment. Roles served: CISO, CAF lead / GRC, IT and OT engineering, internal audit, and consultants running an IGP walk-through with a Competent Authority.

Questions this runbook helps you answer:

- *A3 Asset Management — Can I produce a continuously refreshed inventory of the physical devices, virtual workloads, containers, and cloud services supporting an essential function, and evidence coverage against my CMDB?*
- *B4 System Security / B5 Resilient Networks & Systems — Can I demonstrate structural segmentation between IT corporate estate and OT/SCADA process networks, and micro-segmentation within IT tiers supporting the essential function?*
- *C1 Security Monitoring — Can I evidence continuous logging of network flows and workload processes with synchronised time, and forward telemetry to SIEM/SOAR for retention and correlation?*
- *C2 Proactive Event Discovery — Can I show anomaly detection, threat hunting inputs, and reachability-weighted vulnerability prioritisation for workloads adjacent to essential-function systems?*
- *D1 Response & Recovery — In an incident, can I reconstruct a workload-level timeline (which processes talked to which peers, when, at what volume) as forensic input to the CIRP?*
- *IGP maturity — Which specific CAF outcomes can we credibly move from "Partially Achieved" to "Achieved" by operationalising CSW as the continuous-evidence tier?*

What you'll need. The list of essential functions in scope, the NCSC CAF profile your Competent Authority applies, an inventory of the IT systems and cloud services supporting each essential function, an architecture diagram showing the IT $\rightleftharpoons$ IT/OT DMZ $\rightleftharpoons$ OT boundary (where applicable), your CIRP (Cyber Incident Response Plan), and any prior CAF self-assessment or GovAssure report to identify gaps CSW should close first.

Where to start. Sections 1–2 if you are scoping the CSW deployment; sections 3–6 if you are executing the sensor / policy phased rollout; section 7 for the principle-by-principle IGP mapping (bring this to the Competent Authority conversation); section 8 for the audit-response templates; section 9 for boundaries you must not oversell.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (essential function, CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces

CSW term	Meaning	Why compliance teams care
		drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to CAF IGPs in the **principle-by-principle mapping** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply CAF labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `caf:essential_function=<name>`, `caf:objective=<A|B|C|D>`, `env:<tier>`, `data:<classification>`
- ☐ CSW scope created matching essential-function boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on essential-function scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, cross-function reach)
- ☐ Essential-function owners signed cluster-to-service mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for essential-function scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denials, vulns, audit log (see playbook)

What CSW evidence does not replace

- Board / executive governance evidence (A1) — organisational, not technical.
 - Enterprise risk-management methodology and treatment plans (A2) — process, not telemetry.
 - Supply-chain assurance clauses, supplier audits, and third-party contracts (A4) — procurement.
 - Written service-protection policies, exception registers, and management review (B1) — policy authoring, not enforcement.
 - Staff awareness and training programmes (B6) — HR / learning.
 - Backup content itself, RTO/RPO testing, and disaster-recovery exercises (D1 backup pillar) — CSW contributes forensic reconstruction, not restoration.
 - Post-incident lessons-learned documentation and management follow-up (D2) — process.
-

CSW effectiveness for this framework

- **Continuous, machine-generated evidence** for A3 (asset inventory), B5 (segmentation), C1 (monitoring) — replaces spreadsheet-derived asset lists and quarterly firewall samples that IGP reviewers routinely find insufficient for "Achieved".

- **Structural IT $\rightleftharpoons$ IT/OT DMZ boundary** at the workload layer — a foundational B5 outcome that many operators only have at the network-perimeter tier and which regulators now expect at the workload / host tier.
- **Reachability-weighted vulnerability prioritisation** (B4 + C2) — turns "we scanned" into "we prioritised by exposure to the essential function".
- **Incident-time forensic timeline** (D1) — reconstructs workload-to-workload flow + process history without depending on SIEM log completeness.

Compared to manual programmes. CAF IGPs distinguish between *documented* and *continuously verified* controls; a static Visio diagram plus an annual firewall sample review reads as **Partially Achieved** at best. CSW ties evidence to live workload behaviour and produces queryable exports on demand — the language IGP reviewers look for when awarding **Achieved**.

1. Overview

The CAF is a principle-based, outcome-focused framework. It does not prescribe technology; it asks whether an operator can **demonstrate the outcome**, at a defined level of maturity, for the systems supporting each **essential function**. That framing has direct implications for tooling choice:

- Evidence must be **specific to the essential function** — CSW's **scope** construct maps 1:1 to this notion (label workloads by essential function; scope-scoped exports become the evidence pack).
- Evidence must be **current** — CAF IGPs frequently distinguish "in place" (Partially Achieved) from "regularly tested and continuously verified" (Achieved). CSW's continuous flow + process telemetry satisfies the "continuously verified" bar for the outcomes it covers.
- Evidence must be **testable** — the Competent Authority may request re-execution of a query or a re-export. CSW's inventory / policy / flow queries are reproducible via UI or API.

1.1 CAF structure and where CSW contributes

CAF Objective	Principle	CSW contribution	Coverage rating
A — Managing security risk	A1 Governance	Inputs to board pack: coverage metrics, denies, unresolved exceptions	Supporting
	A2 Risk management	Reachability + attack-surface inputs to threat modelling	Supporting
	A3 Asset management	Primary — continuous	Core

CAF Objective	Principle	CSW contribution	Coverage rating
B — Protecting against cyber attack		workload/service inventory across on-prem + cloud	
	A4 Supply chain	Vendor-egress reconciliation vs. supplier register	Partial
	B1 Service protection policies & processes	Enforcement + drift telemetry proves policies operate	Supporting
	B2 Identity & access control	Workload-to-workload allowlist; least-priv reach evidence (does not replace IAM / MFA / PAM)	Partial
	B3 Data security	Enforces protected paths (TLS-only conduits, deny egress); does not manage keys/crypto primitives	Partial
	B4 System security	Configuration/process baseline + drift; VA integration for patch prioritisation	Strong
	B5 Resilient networks & systems	Primary — microsegmentation, IT/OT DMZ, ADM-derived allowlists	Core
C — Detecting cyber security events	B6 Staff awareness & training	Out of scope	—
	C1 Security monitoring	Primary — continuous flow + process telemetry, SIEM forwarding,	Core

CAF Objective	Principle	CSW contribution	Coverage rating
D — Minimising the impact of incidents	C2 Proactive event discovery	NTP-locked timestamps	Strong
		Anomaly detection; reachability-weighted CVE evidence; threat-intel-fed workspace rules	
	D1 Response & recovery planning	Forensic flow + process reconstruction; policy diff history; does not replace backup/DR	Partial
	D2 Improvements	Historical policy + inventory diffs feed post-incident RCA	Supporting

1.2 Regulatory context (informative)

CAF is not a law; it is an assessment framework used by regulators and departments to demonstrate satisfaction of legal or policy duties:

Sector / entity	Statutory basis	Competent Authority (representative)
Energy — Electricity, Gas, Oil	NIS Regulations 2018	Ofgem (Great Britain); DfE Northern Ireland
Water	NIS Regulations 2018	DWI (Drinking Water Inspectorate, England & Wales); Scottish / NI equivalents
Transport — Air	NIS Regulations 2018	CAA (Civil Aviation Authority)
Transport — Maritime	NIS Regulations 2018	MCA (Maritime and Coastguard Agency)
Transport — Rail	NIS Regulations 2018	ORR (Office of Rail and Road)
Transport — Road (strategic road network)	NIS Regulations 2018	DfT
Healthcare	NIS Regulations 2018	DHSC with NHS

Sector / entity	Statutory basis	Competent Authority (representative)
		England delegated operational role
Digital Infrastructure (DNS, IXPs, TLD registries)	NIS Regulations 2018	Ofcom
Relevant Digital Service Providers (RDSPs)	NIS Regulations 2018	ICO
UK central government	Cabinet Office policy	GSG (Government Security Group) via GovAssure

Confirm the specific competent authority and any sector profile before finalising your CAF evidence — some regulators publish supplementary IGP interpretation guidance.

2. Pre-Deployment Checklist

Before deploying CSW sensors for CAF evidence:

- ☐ **Essential functions defined and named** (per NCSC guidance) — CSW scopes will be labelled to these names.
- ☐ **Sector profile confirmed** with your Competent Authority (baseline CAF vs. sector overlay).
- ☐ **Systems inventory** — list of servers, VMs, containers, cloud services supporting each essential function, with owner and criticality.
- ☐ **IT / OT boundary architecture diagram** — for operators with OT estate; identify jump hosts, IT/OT DMZ workloads, historians, engineering workstations.
- ☐ **Existing CAF self-assessment or GovAssure report** — identify current IGP status per principle so you can target the "Partially Achieved → Achieved" moves CSW enables.
- ☐ **Time source** — confirm NTP source for all in-scope hosts (CAF C1 IGP explicitly calls out synchronised time).
- ☐ **SIEM / SOAR forwarding path** confirmed (CSW will export flow + process telemetry via syslog / Kafka / cloud connector).
- ☐ **Change-management approval** for agent install on operational systems (OT-adjacent systems will need pilot approval).

3. Phase 1 — IT-Side Sensor & Connector Deployment (Days 1–5)

Objective: land coverage on the workloads that support each essential function.

3.1 Server / VM / container agents

```
# Linux (RHEL / Ubuntu / Debian / SLES families)
sudo rpm -ivh tetration-sensor.rpm      # or .deb via dpkg -i
sudo systemctl status tetsensor
sudo tetsensor --status                 # confirms cluster registration

# Windows Server
msiexec /i tetration-sensor.msi /qn
Get-Service tetsensor
```

Deploy in this order:

1. **IT/OT DMZ workloads** (highest CAF B5 evidence value)
2. **Jump hosts, historians, engineering workstations** supporting essential functions
3. **Identity / PKI / DNS / patch / AV / monitoring servers** whose compromise would cascade
4. **Corporate IT workloads with reach into any of the above**

3.2 Cloud & hybrid data paths

Add cloud connectors for essential-function workloads outside the agent footprint:

- **AWS:** connector reads VPC flow logs + EC2/EKS/ECS inventory
- **Azure:** NSG flow logs + VM/VMSS/AKS/App Service inventory
- **GCP:** VPC flow logs + Compute Engine / GKE / Cloud Run inventory
- **Kubernetes:** DaemonSet install for on-prem clusters; API-based inventory for managed control planes

3.3 Sensor validation

- ☐ Every in-scope host visible in CSW Inventory
 - ☐ Flow observations arriving (Investigate → Flows, filter by scope)
 - ☐ Process telemetry arriving (Investigate → Processes)
 - ☐ Time deltas across hosts <1 s (NTP-derived), verified in flow timestamps
-

4. Phase 2 — Scope Architecture for Essential Functions (Days 6–12)

CAF's "essential function" concept maps directly to CSW's **scope** hierarchy.

4.1 Suggested scope architecture

```
Root
├── EssentialFn-<Name-1>                # e.g. "Grid-Control", "Water-
Treatment-Site-A"
│   ├── OT-Support-Tier                # historians, EWS, jump hosts
│   └── IT-OT-DMZ                      # brokers, proxies, DMZ
workloads
│   └── EssFn-Cloud-Tier               # SaaS / IaaS backing services
└── EssentialFn-<Name-2>
```

```

└─ Shared-Services          # identity, PKI, DNS, patch,
monitoring
└─ Corporate-IT            # everything else (default-
least-privilege into essential fns)

```

4.2 Label strategy

Apply consistent labels — they drive scope membership, policy authorship, and evidence export:

Label	Values	Used for
caf:essential_function	<Name> per NCSC definition	Scope binding; per-function evidence packs
caf:objective	A, B, C, D, Shared	Reports grouped by CAF objective
caf:tier	OT-Support, IT-OT-DMZ, Cloud, Shared-Service, Corporate	Tier-specific policy
env	prod, preprod, dev	Environmental separation
data	official, official-sensitive, secret (per HMG classifications)	Government-context data labelling
owner	Essential-function owner e-mail / team	Evidence-pack routing

4.3 Discovery filters for essential-function candidates

Use CSW's search / annotation import to pull candidates from your CMDB:

- Workloads tagged with essential-function name in ServiceNow / equivalent
- Workloads with observed flow to your OT DMZ subnet range
- Workloads hosting historian / SCADA-broker / OPC / Modbus-related services (process names, listening ports)
- Cloud workloads with security-group / NSG rules referencing your OT / operational subnets

5. Phase 3 — Application Dependency Mapping & Baseline (Days 13–28)

5.1 ADM workspace

- Enable ADM per essential-function scope

- Run for ≥ 2 weeks covering full business/operational cycle (peak, off-peak, batch, backup)
- Export cluster-to-service mapping; walk through with the essential-function owner

5.2 ADM review checklist (CAF-oriented)

- ☐ Every observed inbound / outbound flow classified: **expected, unexpected but justified, unexpected — remediate**
- ☐ Cross-essential-function flows explicitly documented (many CAF findings arise from unintended cross-function reach)
- ☐ Vendor / third-party egress paths tagged for A4 (supply chain) reconciliation
- ☐ Shadow IT paths surfaced for A3 completeness

5.3 Baselining for integrity (B4 evidence)

- **Process inventory** snapshot per host (name, path, hash where available, listening ports)
 - **Binary + package inventory** snapshot per host
 - **Listening service** inventory per host
 - Store these as the reference baseline for future drift alerts
-

6. Phase 4 — Policy Design & Enforcement (Days 29–45)

6.1 CAF-aligned policy framework

Design segmentation to satisfy B5 IGPs:

Policy tier	Intent	CAF principle
Corporate IT → OT-Support	Deny by default; allow only jump-host path	B5 (segmentation), B2 (least priv)
OT-Support → IT/OT DMZ	Allow only documented conduits (historian pull, patch push)	B5 (conduit control)
IT/OT DMZ → OT devices	Allow only defined protocol paths (Modbus, OPC UA, DNP3) — enforced at CSW's IT boundary and by OT-native tools deeper in	B5 (structural segmentation)
Shared Services → Any tier	Allow only listed services (DNS, NTP, AD, patch, monitoring)	B2, B4
Any tier → Internet	Deny by default; explicit allowlist for updates, threat feeds, licence servers	B3 (exfil prevention), B5

Policy tier	Intent	CAF principle
Vendor / remote-access → Any tier	Only via broker + jump; log all sessions	A4, B2, D1

6.2 Policy workspace lifecycle

- Build workspace per essential function
- Import ADM cluster proposals as draft policy
- Run **Simulation** mode ≥1 week; review daily for false positives
- Move to **Enforce** after change-board sign-off; record a **negative test** (deliberately denied flow) as evidence enforcement operates

6.3 Enforcement progression

1. Simulation on essential-function scope
2. Enforce on lowest-risk tier (e.g. monitoring readers)
3. Enforce on OT-Support tier during agreed change window
4. Enforce on IT/OT DMZ after ≥30 days of Simulation with zero unexpected denies
5. Retain historical policy versions — they are the "policy diff" evidence for D1 and D2

7. Phase 5 — Principle-by-Principle IGP Mapping

Bring this section to the Competent Authority walk-through. Each row identifies the CAF principle, the IGP theme CSW addresses, the CSW capability that produces the evidence, and the exact artefact you can export.

7.1 Objective A — Managing Security Risk

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
A1 Governance	Board / SMT receives current cyber-risk information	Coverage %, denies count, unresolved exceptions dashboard	Quarterly board pack extract (PDF)
A2 Risk management	Threats to essential functions are dynamically identified	Reachability + attack-surface snapshots per essential-function scope	Reachability report + change delta between snapshots
A3 Asset management	Continuous, comprehensive inventory of assets supporting essential	Workload / service inventory across on-prem + cloud; label discipline;	Inventory CSV + reconciliation report; agent-status report

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
	functions	CMDB reconciliation	
A4 Supply chain	Third-party access to essential-function systems is inventoried and monitored	Vendor-egress observations vs. supplier register; jump-host session evidence	Vendor-egress reconciliation report

7.2 Objective B — Protecting Against Cyber Attack

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
B1 Service protection policies & processes	Policies are enforced and their operation is tested	Policy enforcement + Denied-Connections telemetry proves policy is not aspirational	Policy JSON export + denies report per essential function
B2 Identity & access control	Least-privilege access to systems supporting essential functions	Workload-to-workload allowlist; deny lateral reach; identity-labelled flows when integrated with IAM	Allowlist policy + flow log with user/process context
B3 Data security	Data-in-transit protection & prevention of unauthorised exfiltration	Enforce plaintext-protocol deny; egress-to-Internet allowlist; anomaly on data-volume egress	Policy showing deny for cleartext + egress-anomaly report
B4 System security	Hardened configuration; timely patching; unauthorised code prevented	Process / binary / listening-service inventory; drift alerts; VA connector for reachability-weighted CVE	Baseline vs. current diff; VA reachability report

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
B5 Resilient networks & systems	Segmentation between IT / OT / corporate networks; microsegmentation within tiers	reports ADM-derived allowlists; scope hierarchy mirroring essential-function tiers; conduit-level rules	ADM diagram + policy export + Simulation report
B6 Staff awareness & training	Out of scope — organisational	—	—

7.3 Objective C — Detecting Cyber Security Events

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
C1 Security monitoring	Continuous logging with synchronised time; SIEM/SOAR integration	Flow + process telemetry retention; syslog / Kafka / cloud connector to SIEM; NTP-verified timestamps	Retention policy screenshot; SIEM ingest sample; NTP drift report
C2 Proactive event discovery	Anomaly detection; threat hunting; vulnerability scanning	Behavioural anomaly alerts (new listener, new peer, unusual volume); reachability-weighted CVE alerts; threat-intel-fed workspace rules	Anomaly alert catalog; CVE-reachability report; workspace change history

7.4 Objective D — Minimising the Impact of Incidents

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
D1 Response & recovery	Incident response is exercised and	Historical flow + process telemetry;	Forensic timeline export; policy-

CAF principle	IGP theme (CSW-addressable)	CSW capability	Evidence artefact
planning	evidenced; forensic reconstruction is possible	policy diff timeline; per- workload change history	diff report for the incident window
D2 Improvements	Lessons learned drive control changes	Policy + inventory diff history feeds RCA; workspace change log traces control evolution	Workspace change log; policy-diff summary per incident

8. Auditor / Competent-Authority Response Guide

When the Competent Authority (Ofgem, DWI, CAA, ORR, MCA, DfT, DHSC/NHS England, Ofcom, ICO) or GovAssure assessor asks for evidence:

Authority asks	You provide
"Show your inventory of assets supporting essential function X as of [date]"	CSW Inventory snapshot filtered by <code>caf:essential_function=X</code> , dated
"Demonstrate structural segmentation between corporate IT and OT"	Workspace export + ADM diagram + Simulation showing zero allowed cross-boundary flows outside documented conduits
"Provide flow-level evidence for incident [ID] between [t0] and [t1]"	CSW flow + process timeline export scoped to the affected workloads for that window
"Show how B4 patch prioritisation reflects essential-function exposure"	Reachability-weighted CVE report; workspace rules referencing CVE feed
"Show C1 continuous monitoring is operating for essential function X"	Retention screenshot; SIEM ingest proof; NTP-drift report; alerting rule catalog
"Show how policy exceptions are managed and reviewed under B1"	Exception register + policy workspace change history + management review minutes (paired with CSW policy diffs)
"Show that segmentation policy is <i>tested</i> , not just written (Achieved-tier IGP)"	Simulation report + Denied-Connections evidence + a documented negative-test outcome

9. Boundaries — what CSW does **not** cover

- **Level 0–2 OT devices** (PLCs, RTUs, IEDs, drives, field instruments) — no CSW agent; pair with Cisco Cyber Vision / Claroty / Nozomi for asset discovery, ICS protocol analytics, and device-level integrity.
 - **OT protocols** (Modbus, DNP3, S7, OPC UA, BACnet, IEC 60870-5) at wire speed — outside CSW's inspection scope.
 - **Cryptographic primitives and key management** (B3) — CSW may enforce **paths** (TLS-only) but does not replace PKI / HSM governance.
 - **IAM / MFA / PAM** (B2) — CSW consumes identity context if integrated; it does not authenticate humans, mint tokens, or manage privileged sessions.
 - **Backups, immutability, RTO/RPO testing** (D1 recovery pillar) — CSW contributes forensic evidence, not restoration.
 - **Board governance, policy authoring, supplier contracting, training records** (A1, A2 methodology, A4 procurement, B1 authoring, B6) — organisational; CSW provides inputs, not the process.
 - **CAF Achieved-status certification** — CAF is not a certification scheme; the Competent Authority awards the IGP status. CSW evidence *supports* an Achieved award for the outcomes it covers; it does not confer it.
-

10. Common pitfalls

Pitfall	Mitigation
Labelling scopes by team or business unit instead of essential function	Anchor labels to the NCSC essential-function names your Competent Authority has agreed
Presenting a static architecture diagram as B5 evidence	Add ADM diagram (behaviour-derived) alongside; regulator asks for both
Treating a scan report as B4 evidence for "prioritised patching"	Pair scan output with reachability-weighted CVE report so priority is defensible
Enforcing before Simulation on OT-adjacent systems	Simulation ≥ 30 days on OT-adjacent tier before Enforce; document negative test after Enforce
Missing NTP evidence for C1	Include NTP source, drift report, and a flow timestamp comparison across ≥ 2 hosts in every C1 pack
Conflating "policy exists" with "policy operates" for IGP Achieved	Ship Denied-Connections evidence + a documented negative-test outcome in every quarterly pack
Ignoring cross-essential-function reach	Explicit deny rules between essential-function scopes; ADM must show

zero cross-reach outside documented conduits

11. Audit preparation & evidence export

11.1 Quarterly CAF pack (per essential function)

- ☐ Inventory CSV filtered by `caf:essential_function=<X>`
- ☐ Scope-membership screenshot (with label filters visible)
- ☐ ADM diagram export (PDF)
- ☐ Policy JSON export
- ☐ Denied-Connections report for the quarter (with negative-test entry highlighted)
- ☐ Reachability-weighted CVE report
- ☐ Anomaly / new-listener alert log
- ☐ Workspace change history (policy diff timeline)
- ☐ NTP-drift report
- ☐ SIEM ingest sample proving telemetry flow is live
- ☐ Cover sheet mapping each artefact to CAF principles and IGP maturity claim

11.2 Bash helpers (on analysis workstation)

Verify exported policy archive integrity (after UI download)
`sha256sum caf-<essfn>-policy-*.json.gz`

Redact non-production subnets before sharing with an assessor
`sed -E 's/10\.99\.[0-9]+\.[0-9]+/10.99.x.x/g' adm-<essfn>.txt > adm-<essfn>.redacted.txt`

Generate a per-principle evidence-index CSV from a manifest
`awk -F, 'NR>1 {print $1,"$2","$3}' evidence-manifest.csv > caf-evidence-index.csv`

Related Frameworks

- [NIS2 \(EU 2022/2555\)](#) — EU parallel to the UK NIS regime; Article 21(2) measures overlap heavily with CAF Objectives A–D.
- [NIST SP 800-82 Rev. 3](#) — OT security guidance underpinning the IT/OT boundary approach in CAF B5.
- [IEC 62443](#) — IACS zones-and-conduits reference used by many CAF operators for OT segmentation.
- [NERC CIP](#) — US analogue for BES entities; useful cross-walk if you operate on both sides of the Atlantic.

- [NIST CSF 2.0](#) — outcome-based framework with a similar Govern / Identify / Protect / Detect / Respond / Recover structure.
 - [ISO/IEC 27001:2022](#) — ISMS backbone many UK operators already run alongside CAF.
 - [CISA Zero Trust Maturity Model](#) — pillar-based reference used to characterise CAF B2 / B5 maturity.
 - [UK Cyber Essentials](#) — UK baseline control set often paired with CAF for supply-chain assurance under A4.
-

Appendix A — Sample essential-function policy fragment (illustrative)

Do not paste verbatim into production. Replace scope names, addresses, and services with values from your architecture. Syntax is conceptual; exact API/UI format follows the CSW product version.

```
workspace: CAF-EssFn-Water-Treatment-Site-A
mode: simulation          # move to enforcement after change-board
sign-off + 1 week clean simulation
default_action: deny
rules:
- name: historian-pull-from-scada
  action: allow
  src_scope: EssFn-Water-Treatment-Site-A/OT-Support-Tier/Historian
  dst_scope: EssFn-Water-Treatment-Site-A/IT-OT-DMZ/SCADA-Broker
  services:
    - tcp/4840          # OPC UA
    - tcp/1883          # MQTT (documented conduit only)
- name: patch-push-from-shared
  action: allow
  src_scope: Shared-Services/Patch
  dst_scope: EssFn-Water-Treatment-Site-A/OT-Support-Tier
  services:
    - tcp/443
  schedule: change-window-only
- name: jump-host-admin
  action: allow
  src_scope: Shared-Services/Jump-Hosts
  dst_scope: EssFn-Water-Treatment-Site-A/OT-Support-Tier
  services:
    - tcp/22
    - tcp/3389
- name: deny-corp-to-essfn
  action: deny
  src_scope: Corporate-IT
  dst_scope: EssFn-Water-Treatment-Site-A
  log: true             # supports C1 evidence and D1 forensic
timeline
- name: alert-unknown-east-west
  action: alert
  src_scope: EssFn-Water-Treatment-Site-A
```

```
dst_scope: EssFn-Water-Treatment-Site-A
match: not_in_conduit_allowlist
```

Appendix B — CAF IGP maturity cheatsheet (CSW's contribution)

Move	CSW contribution
A3 Partially → Achieved	Continuous inventory + CMDB reconciliation + agent-coverage report
B5 Partially → Achieved	ADM diagram (behaviour-derived) + workspace enforcement + Simulation clean-run evidence
C1 Partially → Achieved	Continuous flow/process telemetry + SIEM ingest proof + NTP drift report + retention screenshot
C2 Partially → Achieved	Anomaly alert catalog + reachability-weighted CVE report + threat-intel-fed workspace rules
D1 Partially → Achieved (forensic pillar)	Historical flow + process timeline + policy diff timeline as CIRP appendix

Disclaimer

This runbook maps Cisco Secure Workload capabilities to the outcomes described in the UK NCSC Cyber Assessment Framework (CAF v3.2, November 2024) for the purpose of aiding operator evidence collection. It is **not** an NCSC-endorsed certification, is **not** a substitute for an independent CAF assessment or GovAssure engagement, and does **not** confer any IGP maturity status. Awarding of IGP status is the responsibility of the operator's Competent Authority (Ofgem, DWI, CAA, ORR, MCA, DfT, DHSC/NHS England, Ofcom, ICO) or GovAssure assessor. Cisco Secure Workload is one component of an evidence programme that also depends on organisational governance, procurement, HR, business continuity, and training controls outside CSW's technical scope. Confirm your sector profile and any Competent Authority-specific guidance before finalising evidence.